

README: KIT INTEGRAL DE ENCUESTA DE CIBERSEGURIDAD

Modelo ADAM - Evaluación de Riesgos, Vulnerabilidades, SIEM y Concienciación

Versión: 1.0

Fecha Publicación: Enero 2026

Idioma: Español

Clasificación: Uso Estratégico



CONTENIDO DEL KIT

Este Kit Integral contiene **7 documentos profesionales** para diseñar, implementar y ejecutar una evaluación exhaustiva de ciberseguridad basada en el modelo ADAM (Applied to Cybersecurity Risks), alineado con NIST CSF 2.0, NIS2, ISO 27001 y regulaciones españolas.

Documentos Incluidos:

1. 1-Encuesta-Integral.md (Modelo de Encuesta)
2. 50+ preguntas estructuradas
3. 14 secciones cubriendo: Gobernanza, Vulnerabilidades, Penetración Testing, SIEM, Concienciación, Infraestructura, Continuidad, Supply Chain, OT/IoT, Financiero
4. Escalas 0-5 para cada respuesta
5. Mapeado a NIST CSF 2.0 (6 dominios)
6. 2-Guia-Metodologica.md (Metodología Cálculos)
7. GQM Framework explicado
8. Cálculo del Índice Global de Madurez (IGM)
9. Fórmulas ponderadas por dominio
10. Análisis FAIR simplificado
11. Modelos ROSI (Return on Security Investment)
12. Benchmarking por sector
13. Roadmap 18 meses con ROI proyectado
14. 3-Narrativa-Explicativa.md (Contexto Literario)
15. Tono irónico, ameno y constructivo
16. 6 actos: Introducción → Pilares NIST → Aritmética → Casos reales → ROI → Moraleja
17. Explicación conceptual para no-técnicos
18. Justificación empresarial de medición
19. 4-Mapeo-Normativo.md (Compliance Mapping)
20. Matriz exhaustiva: Preguntas ↔ Estándares
21. Cobertura: NIST CSF, ISO 27001, NIS2, ENS, GDPR, CRA, CMMC
22. Por cada pregunta: ¿Cuál requisito regulatorio cumple?
23. Auditable: Evidencia requerida
24. 5-Plantilla-Excel.md (Implementación Hoja Cálculo)

25. Estructura 6 hojas: Datos encuesta, Cálculo IGM, Comparativas, ROI, Roadmap, Dashboard

26. Fórmulas Excel/Google Sheets

27. Auto-cálculo IGM y Maturity Level

28.

Visualizaciones recomendadas (Radar, Gauge, Timeline)

29.

6-Reporte-Ejecutivo.md (PowerPoint Template)

30. 10 diapositivas completas

31. Resumen ejecutivo (1 página)

32. Radar NIST CSF visual

33. Tablas vulnerabilidades, SIEM, Roadmap

34. ROI y Business Case

35.

Riesgos y Mitigaciones

36.

7-README.md (Este archivo)

37. Guía de uso del Kit

38. Casos de uso

39. Paso a paso implementación

40. Soporte y actualizaciones

Mapeado a NIST CSF 2.0 (6 dominios)

2-Guia-Metodologica.md (Metodología Cálculos)

Roadmap 18 meses con ROI proyectado

3-Narrativa-Explicativa.md (Contexto Literario)

Justificación empresarial de medición

4-Mapeo-Normativo.md (Compliance Mapping)

Auditable: Evidencia requerida

5-Plantilla-Excel.md (Implementación Hoja Cálculo)

Visualizaciones recomendadas (Radar, Gauge, Timeline)

6-Reporte-Ejecutivo.md (PowerPoint Template)

Riesgos y Mitigaciones

7-README.md (Este archivo)

CASOS DE USO PRINCIPALES

UC1: Auditoría Interna de Postura de Ciberseguridad

Audiencia: CISO, Responsable GRC, Auditor Interno

Frecuencia: Trimestral

Tiempo: 3-4 semanas

Proceso:

1. Rellenar Encuesta Integral (Secciones 1-14)
2. Validar respuestas con evidencia documental
3. Importar a Plantilla Excel
4. Auto-calcular IGM
5. Generar Reporte Ejecutivo
6. Identificar gap analysis
7. Presentar Junta con Roadmap

Resultado: IGM score (0-5) + Maturity Level (0-4) + Recomendaciones cuantificadas

UC2: Business Case de Inversión Ciberseguridad

Audiencia: CFO, Directiva, Junta

Cuando: Solicitar presupuesto anual / Justificar proyecto

Proceso:

1. Realizar encuesta (estado actual)
2. Proyectar IGM post-inversión
3. Calcular ROSI usando modelos FAIR (Sección 12 + Guía Metodológica)
4. Preparar Roadmap 18 meses
5. Presentar con ROI (típicamente 600-800%)
6. Obtener aprobación presupuestaria

Resultado: Presupuesto aprobado basado en números, no conjeturas

UC3: Auditoría Externa / Cumplimiento Regulatorio

Auditor: Externo (Firma Big 4, KPMG, etc.)

Estándares: NIS2, ISO 27001, GDPR, ENS

Proceso:

1. Entregar Encuesta pre-rellenada a organización
2. Auditor valida respuestas vs. evidencia
3. Usa Mapeo Normativo para alinear a requisitos específicos
4. Genera IGM auditado (independiente)
5. Produce certificación o gaps finding

Resultado: Auditoría con métricas objetivas, no juicios subjetivos

UC4: Benchmarking Competitivo

Casos:

- Comparar IGM con competencia (sectorial)
- Evaluar atractivo inversión (investors due diligence)
- Vendetta contra proveedores críticos

Resultado: Score comparable de ciberseguridad

UC5: Evaluación de Proveedores/Supply Chain

Audiencia: Procurement, Risk Management

Proceso:

1. Enviar Encuesta a proveedores críticos (versión simplificada)
2. Recopilar IGM de terceros
3. Evaluar riesgo: IGM <2.5 = Alto riesgo → acción
4. Actualizar anualmente
5. Integrar en contratación/SLA

Resultado: Riesgo supply chain cuantificado



ESTRUCTURA TEMPORAL

Implementación Inicial (Mes 1)

Actividad	Responsable	Horas	Output
Rellenar Encuesta	CISO + Equipos	40h	50+ respuestas validadas
Cálculo IGM	GRC	8h	Plantilla Excel con score
Análisis Gaps	Consultor	16h	Matriz gaps con priorización
Roadmap 18M	CISO + Consultor	24h	Plan inversión cuantificado
Reporte Ejecutivo	Comunicación	12h	Presentación Junta
Total		100h	Documentación completa

Ciclo de Revisión (Trimestral)

Q	Actividad	Horas	Resultado
Q1	Encuesta + Cálculo IGM	20h	Baseline + Reporte
Q2	Encuesta abreviada + Trending	15h	Follow-up + Ajustes
Q3	Encuesta + Análisis cambios	20h	Validación progreso
Q4	Encuesta completa + Anual	30h	Review anual + Planning 2027

GUÍA DE IMPLEMENTACIÓN PASO A PASO

Paso 1: Preparación (Semana 1)

- ☐ Nombrar CISO o Responsable GRC como propietario del proyecto
- ☐ Descargar y revisar todos 7 documentos del Kit
- ☐ Identificar stakeholders internos (TI, Seguridad, Cumplimiento, Finanzas)
- ☐ Reservar presupuesto: €5-10k (consultoría externa si no hay expertise)
- ☐ Crear cuenta Google Drive o SharePoint para compartir plantillas

Paso 2: Formación Equipos (Semana 2)

- ☐ Sesión de 2h: Explicar GQM Framework + NIST CSF 2.0 (usar Narrativa Explicativa)
- ☐ Sesión de 2h: Demo cómo rellenar Encuesta (usar ejemplos Sección 1-3)
- ☐ Sesión de 1h: Demostración cálculo IGM en Excel
- ☐ Q&A + Aclaraciones

Paso 3: Rellenar Encuesta (Semanas 3-4)

- ☐ Dividir en equipos por sección:
 - Secciones 2-3: Equipo Gobernanza (CISO, GRC)
 - Secciones 4-5: Equipo Técnico (CTO, SOC)
 - Secciones 6-7: Equipo Respuesta (Incident Commander, HR)
 - Secciones 8-11: Equipo Infraestructura (Arquitecto, DevSecOps)
 - Sección 12: CFO/Finanzas
- ☐ Responder basado en EVIDENCIA, no conjeturas
- ☐ Adjuntar certificados, reportes, políticas como soporte
- ☐ Sesión grupal: Validar discrepancias / Consenso

Paso 4: Cálculo IGM (Semana 5)

- ☐ Importar respuestas a Plantilla Excel
- ☐ Ejecutar cálculos automáticos
- ☐ Validar no hay errores (chequear sumatorias)
- ☐ Generar Gráfico Radar (Visual NIST CSF)
- ☐ Crear Dashboard ejecutivo (KPI cards, Vulnerabilidades, ROI)

Paso 5: Análisis Gaps (Semana 6)

- ☐ Usar Guía Metodológica: Sección 3 (Análisis por Dominio)
- ☐ Identificar gaps vs. Benchmarks
- ☐ Priorizar por Impacto × Esfuerzo
- ☐ Crear matriz de recomendaciones
- ☐ Cuantificar costo/beneficio de cada iniciativa

Paso 6: Roadmap 18 Meses (Semana 7)

- ☐ Definir Q1-Q6:
 - Q1: Quick Wins (MFA, Policy, Training)
 - Q2-Q3: Strategic (SIEM, Pentest, DR)
 - Q4-Q6: Optimization (Red Team, Zero Trust, Supply Chain)
- ☐ Asignar presupuesto por trimestre
- ☐ Estimar IGM proyectado post-cada fase
- ☐ Calcular ROI acumulativo
- ☐ Identificar dependencias/riesgos

Paso 7: Presentación Ejecutiva (Semana 8)

- ☐ Usar Plantilla Reporte Ejecutivo
- ☐ Customizar con datos de organizacióm
- ☐ Generar 3 versiones:
 - Ejecutiva (1 página): IGM + Roadmap + Presupuesto
 - Técnica (5 páginas): Detalles por dominio
 - Completa (10 páginas): Todo + Anexos
- ☐ Presentar a Junta/Directiva
- ☐ Obtener aprobación presupuesto Q1



CHECKLIST DE VALIDACIÓN

Antes de presentar IGM a auditoría/directiva:

- ☐ Todas las 50 preguntas respondidas (sin "N/A")
- ☐ Respuestas alineadas con evidencia documental (certificados, reportes)
- ☐ No hay errores matemáticos en Excel (validar sumatorias)
- ☐ Gaps identificados vs. benchmarks del sector
- ☐ Roadmap con timeline, presupuesto, ROI realista
- ☐ Reporte sin confidencial (datos anonimizados si se comparte)
- ☐ Presentación aprobada por CISO + CFO antes de mostrar Junta



SOPORTE Y MANTENIMIENTO

Actualización Anual (Recomendada)

- Revisar benchmarks sector (pueden cambiar año a año)
- Actualizar ponderaciones si cambian regulaciones (NIS2, GDPR)
- Recalibrar con auditoría externa
- Publicar nueva versión si mejoras significativas

Problemas Comunes

P: "Nuestro IGM es 1.8, pero nos creen muy seguros"

R: Probable sobre-optimismo en respuestas. Usar auditoría externa para validar.

P: "¿Debería publicar nuestro IGM públicamente?"

R: No recomendado. Es información sensible (riesgo de ataque). Mantener confidencial.

P: "¿Cómo comparamos con competencia?"

R: Use Benchmarking anónimo con consorcios (ej: ISMS Forum), no publicación directa.

CONTACTO Y ACTUALIZACIONES

- Versión Actual: 1.0 (Enero 2026)
- Próxima Actualización: Julio 2026 (post-transposición NIS2)
- Contacto Soporte: [Email/URL de soporte]

LICENCIA Y USO

Licencia: Creative Commons CC-BY-SA

Uso Permitido:

-  Uso interno organizacional sin límite
-  Adaptaciones para contexto local/sector
-  Compartir con auditorías externas/consultores bajo NDA

Uso NO Permitido:

-  Vender/Comercializar sin atribución
-  Remover referencias al original
-  Usar para marketing sin consentimiento

RECURSOS ADICIONALES

Marcos de Referencia:

- NIST Cybersecurity Framework 2.0: <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>
- ISO/IEC 27001:2022: <https://www.iso.org/standard/27001>
- Directiva NIS2: <https://eur-lex.europa.eu/eli/dir/2022/2555/oj>
- INCIBE Indicadores: <https://www.incibe.es/>

Herramientas:

- GQM Templating: Goal-Question-Metric Framework
- FAIR Analysis: Factor Analysis of Information Risk (Open Group)
- Benchmarking: ISMS Forum, CIS Benchmarks

CONCLUSIÓN

Este Kit proporciona **metodología rigurosa, ejecutable y auditable** para evaluar postura cibernética con:

- ✓ **Rigor:** GQM + NIST + FAIR (no conjeturas)
- ✓ **Compleitud:** 14 secciones, 50+ preguntas, 100% cobertura NIST CSF
- ✓ **Practicidad:** Templates Excel, PowerPoint, guías paso a paso
- ✓ **Compliance:** Mapeo a NIS2, ISO 27001, GDPR, ENS, CRA
- ✓ **Financiero:** ROI cuantificado, payback <90 días típicamente

Próximo Paso: Descargar documentos, designar CISO como propietario, y comenzar Paso 1 (Preparación).

*Kit desarrollado por Consorcio de Científicos de Datos y Estrategas de Ciberseguridad
Enero 2026 | Uso Estratégico | Distribuya responsablemente*